Approving rare, powerful actions with a device you hold

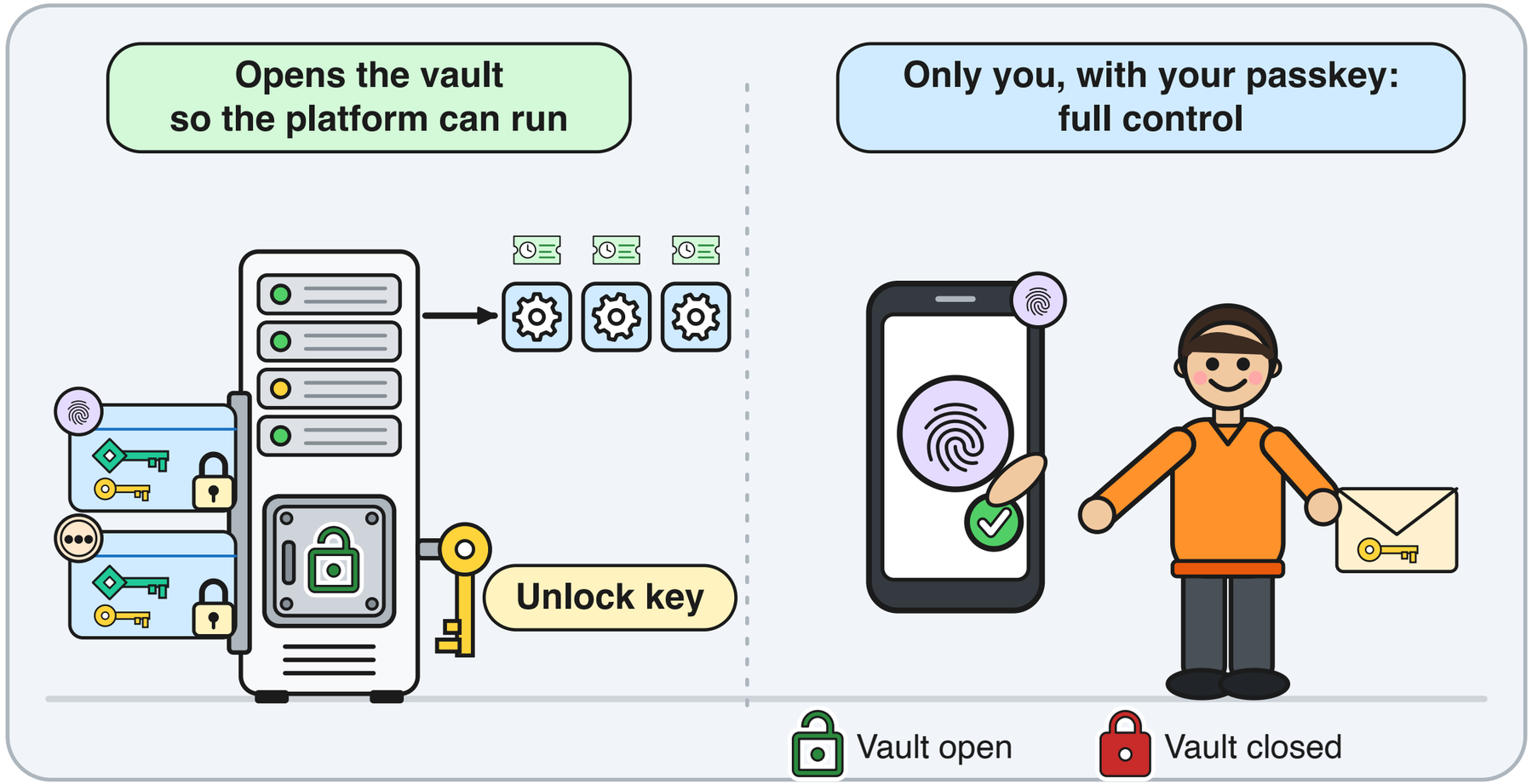
A proposed design for the sandbox lane

Follow nine steps, from an empty machine to losing a device.

The walkthrough describes the intended design. Implementation is pending.

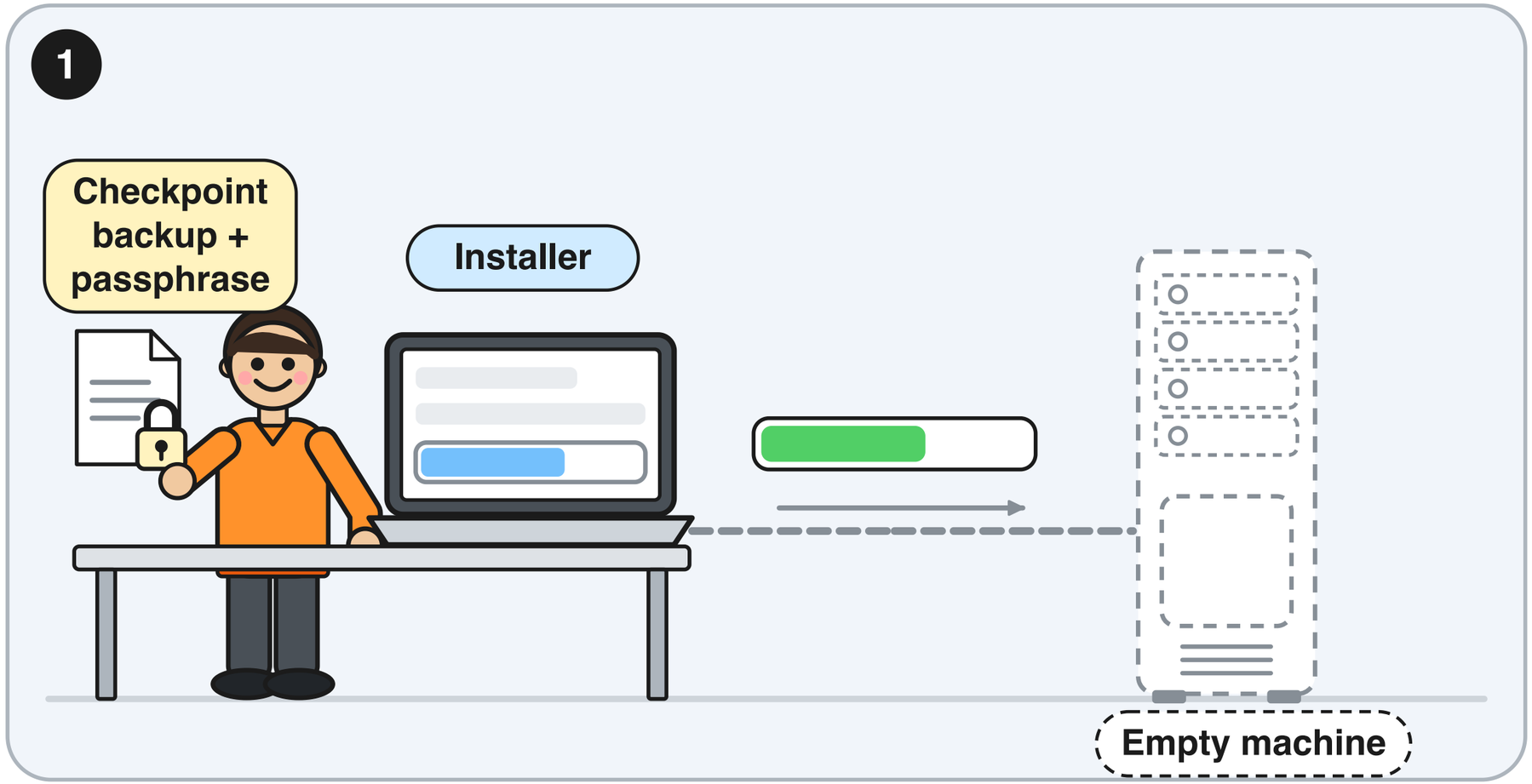
The final slides offer recommendations for decisions that remain open.

The idea in one picture



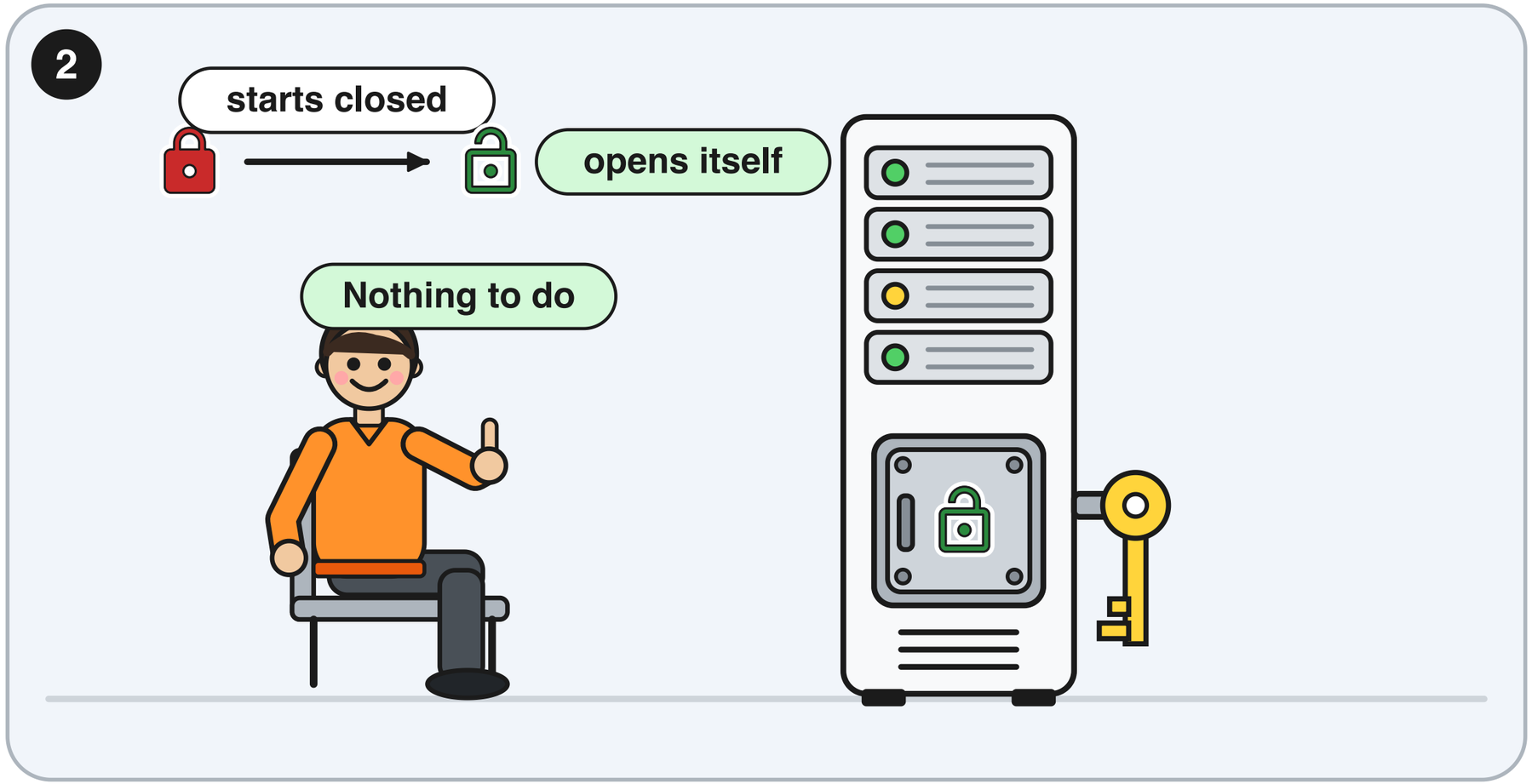
The machine opens the vault so the platform can run. Only you, with your passkey, can take full control.

Step 1: start with one empty machine



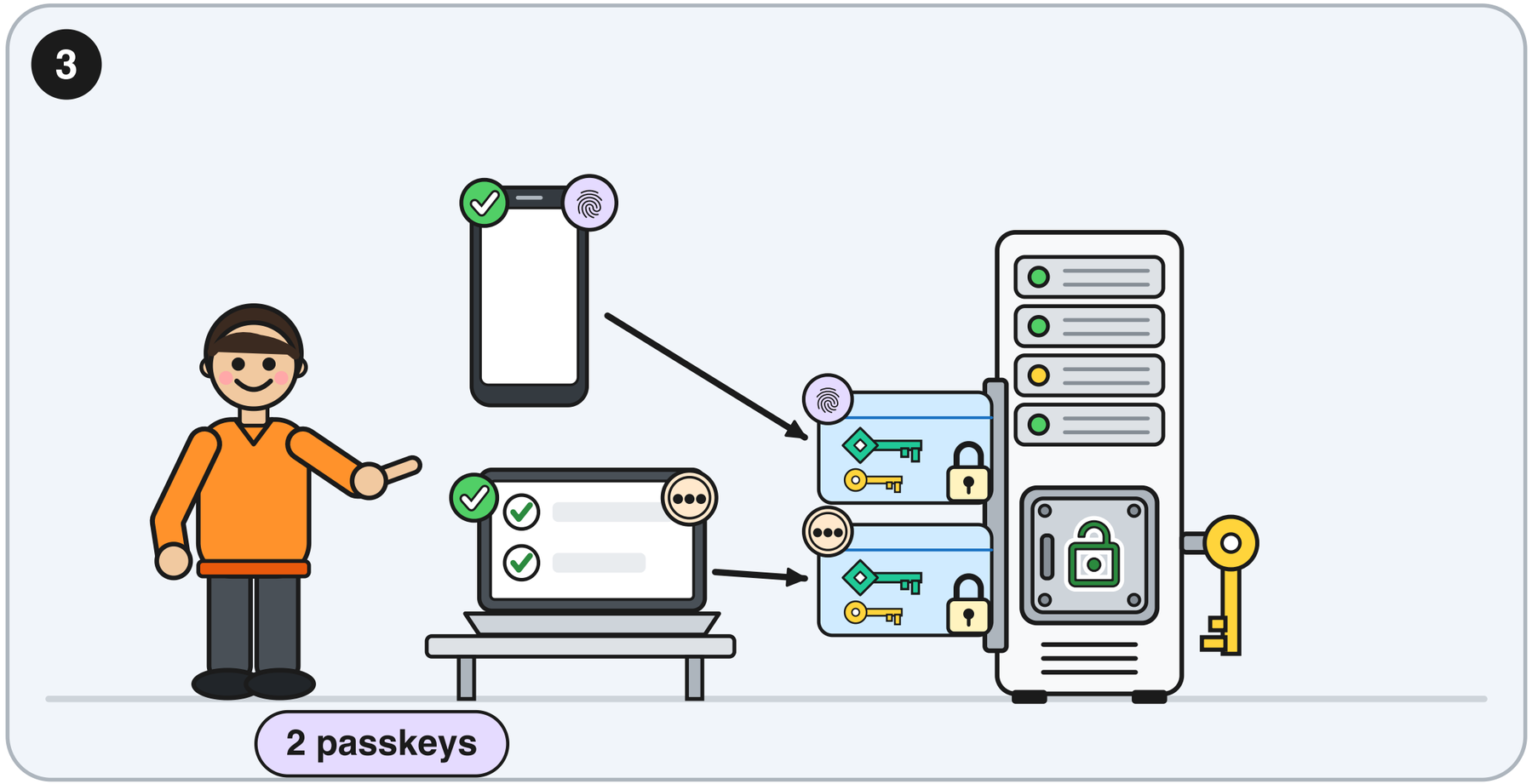
You start the installer and point it at one empty machine. You keep the backup and its passphrase.

Step 2: the machine unlocks itself



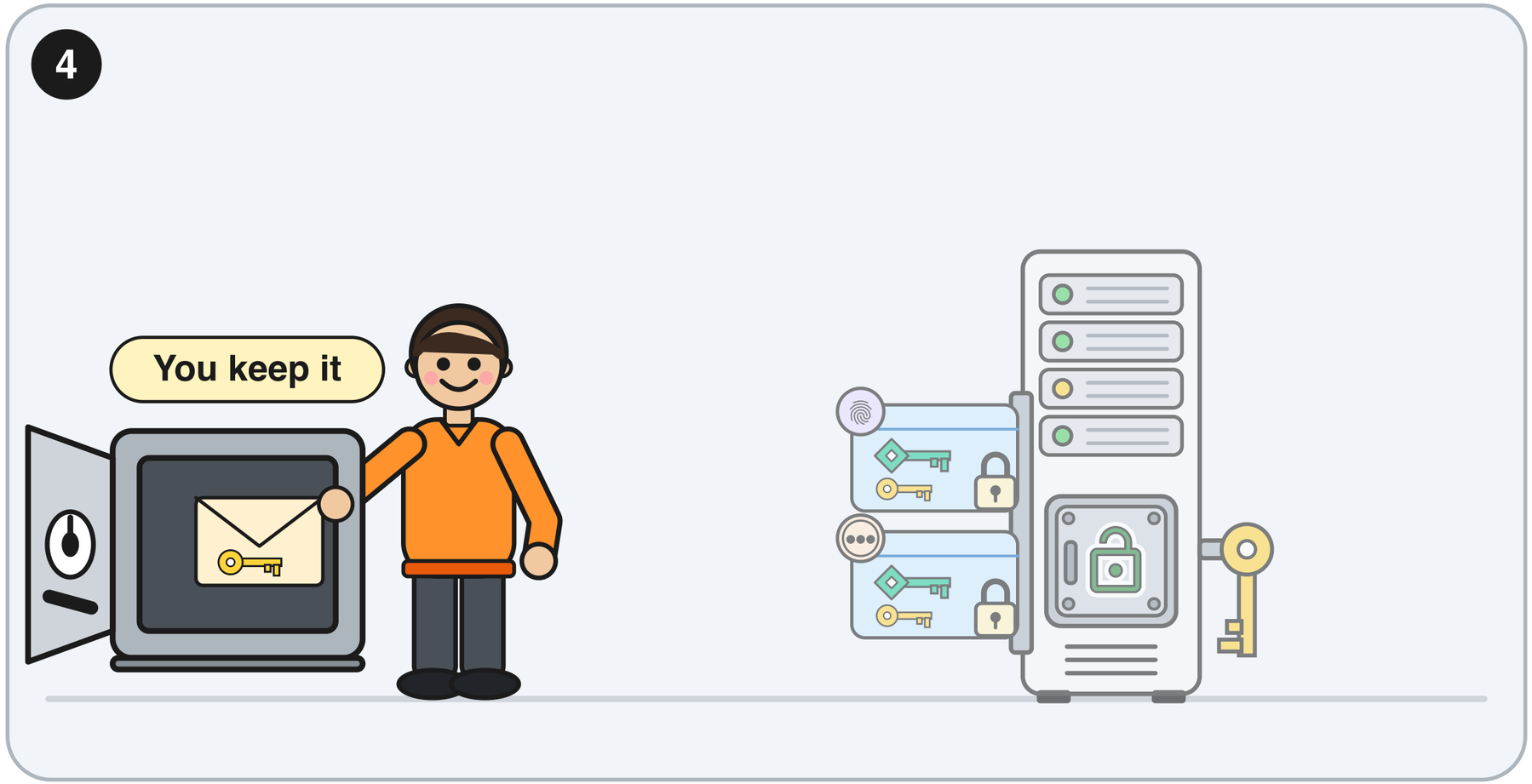
You do nothing. The vault opens by itself 🔓.

Step 3: enrol two passkeys



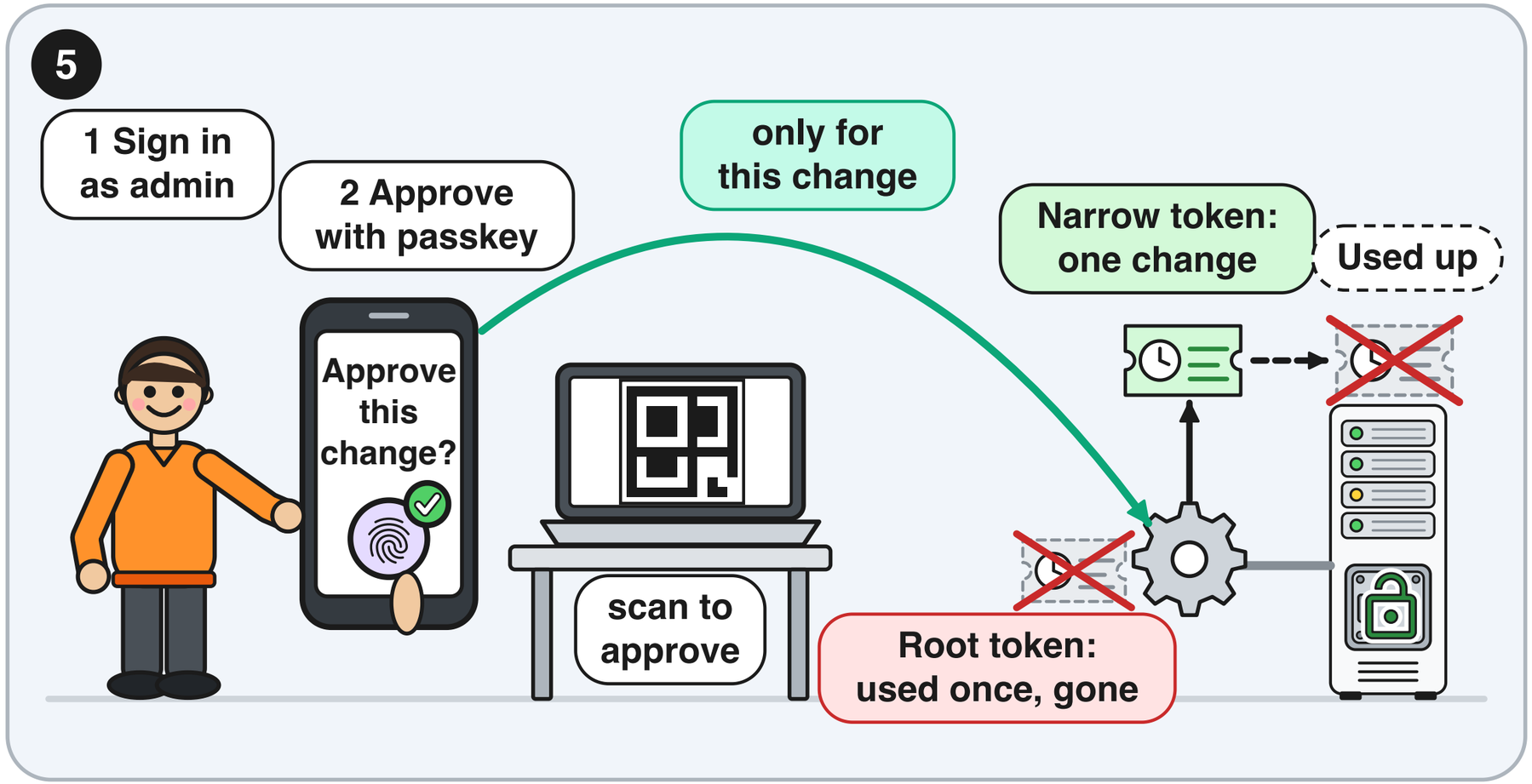
Each enrolled passkey has its own encrypted copy, stored on the machine.

Step 4: keep the recovery package



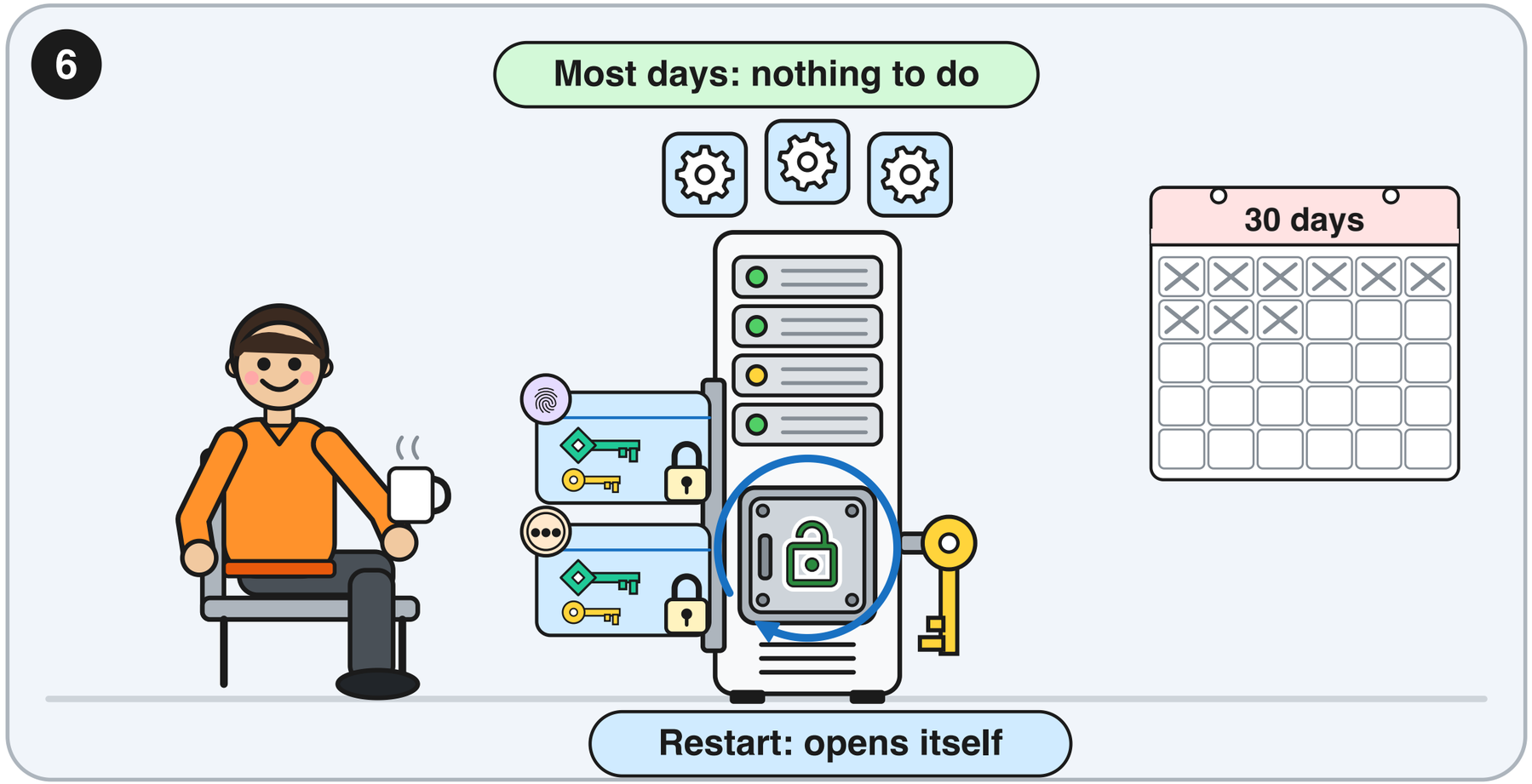
You keep it. It holds one copy of the unlock key.

Step 5: a root token for one planned change



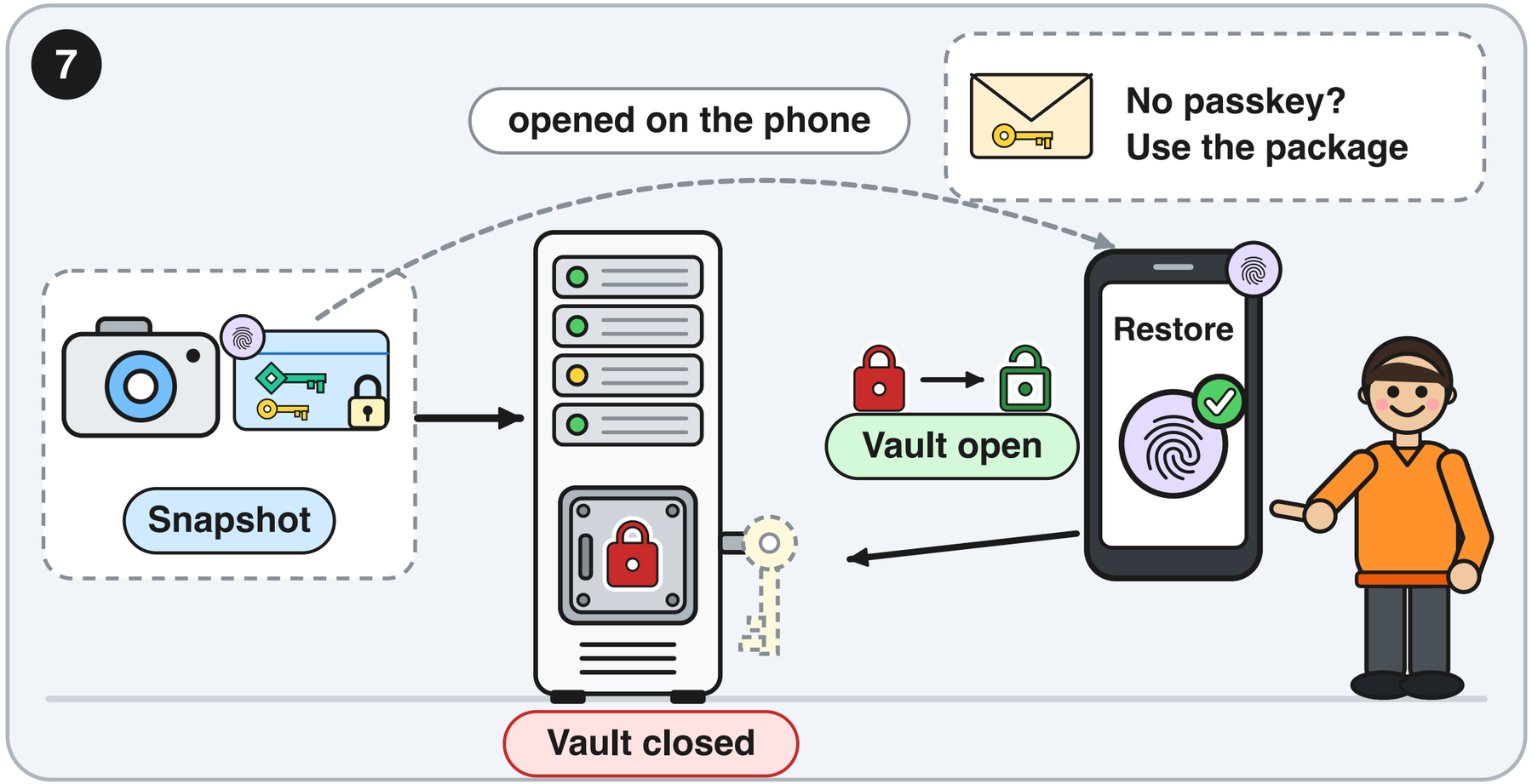
You sign in as the admin, then approve with your passkey. The executor uses the root token once to make a narrow token, and revokes the root token at once.

Step 6: a normal day



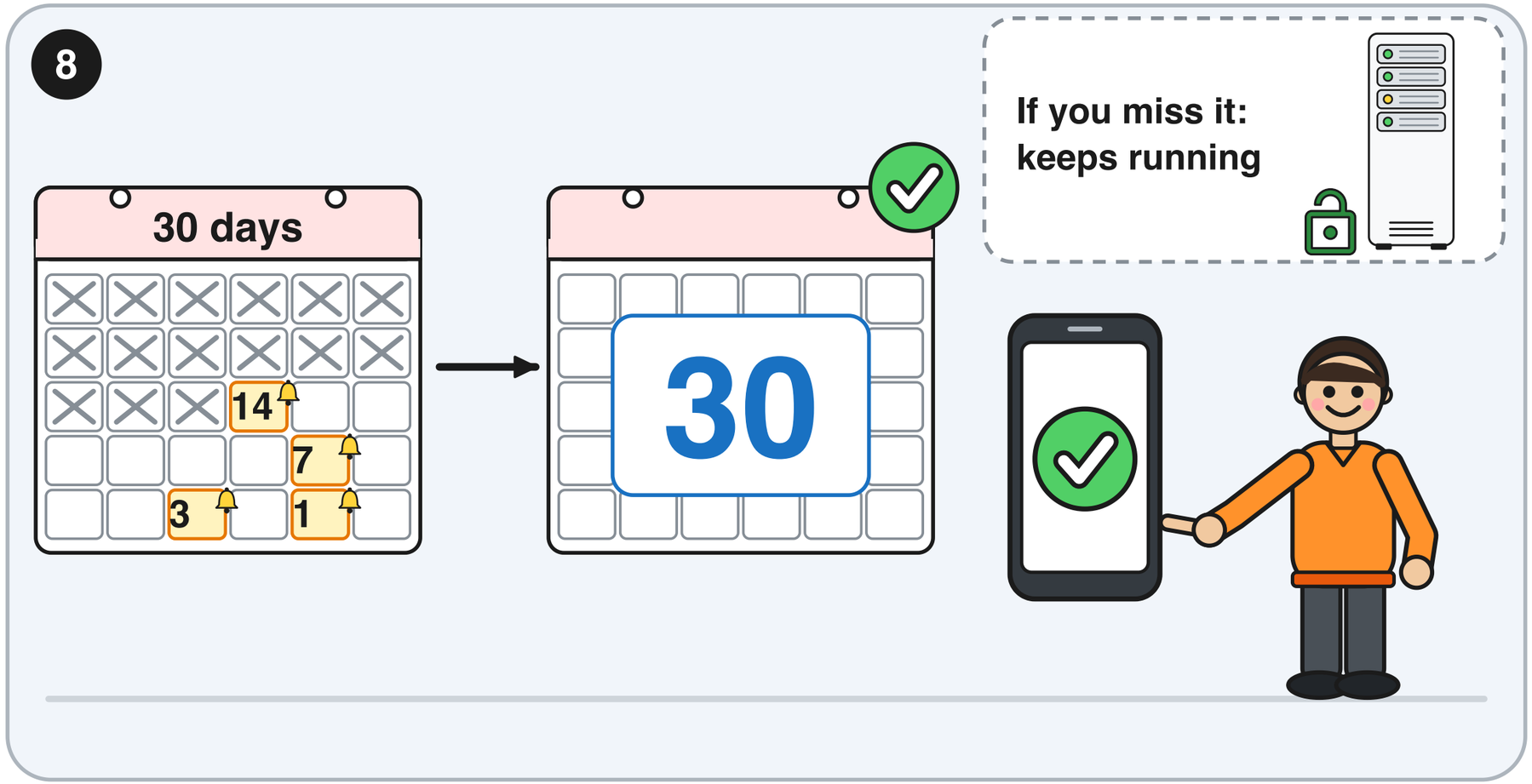
Most days, you do nothing.

Step 7: restore from a snapshot



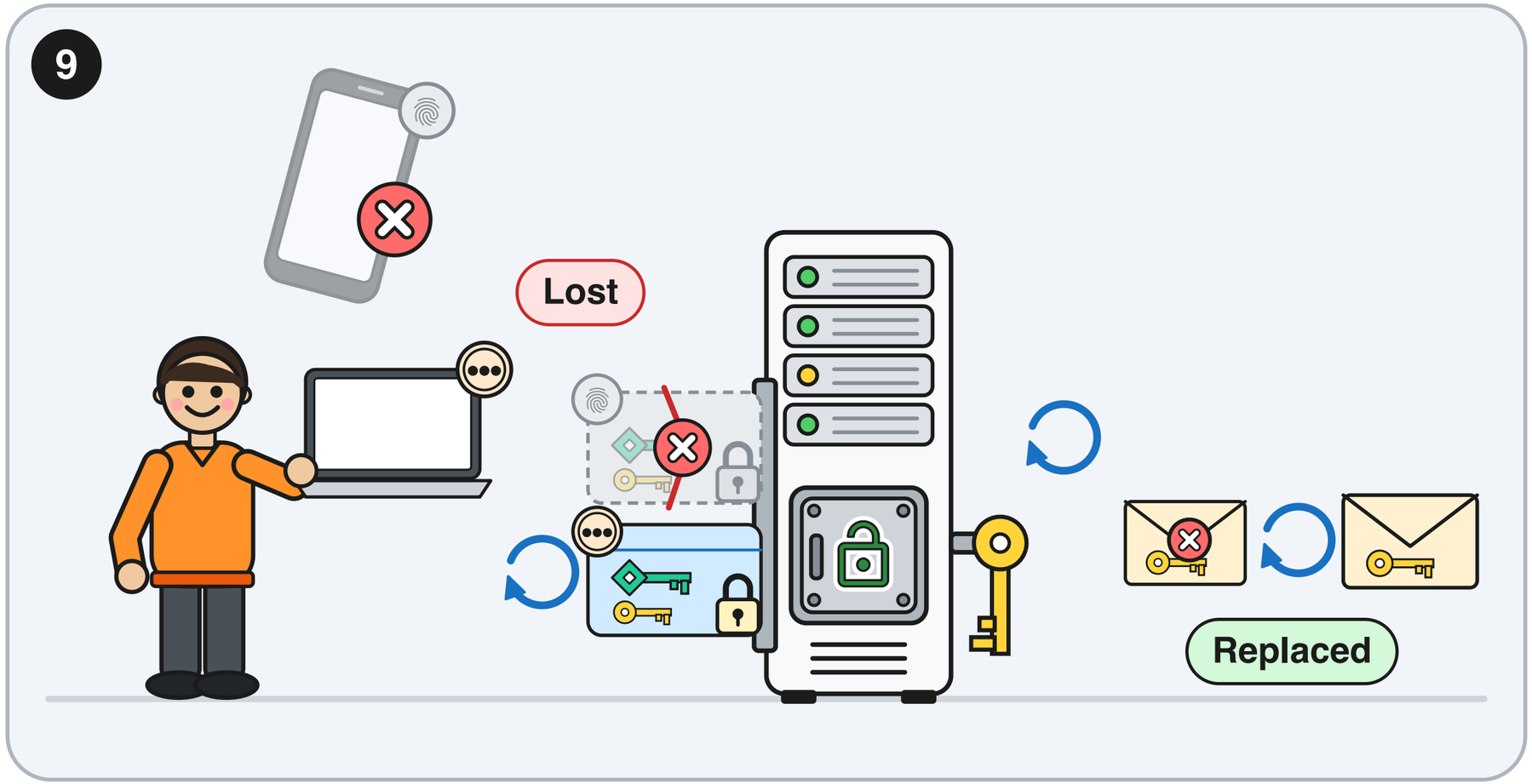
You confirm with your passkey. The copy stored with the snapshot gives back the unlock key.

Step 8: check in every 30 days



One confirmation on a device starts a new 30 days.

Step 9: lose a device, keep control



Remove the lost passkey. The keys are replaced and the recovery package is reissued.

THE IDEA

The machine opens the vault so the platform can run. Only you, with your passkey, can take full control.

With the vault open 🔓, the system hands secrets to the apps through a helper. Each service and automation identity reads only what its policy allows. The admin manages app secrets day to day, and the system rotates secrets and takes backups.

Every request still needs a sign-in. An open vault does not give secrets to anyone who asks. When the vault is closed 🔒, nothing new can be issued or rotated.

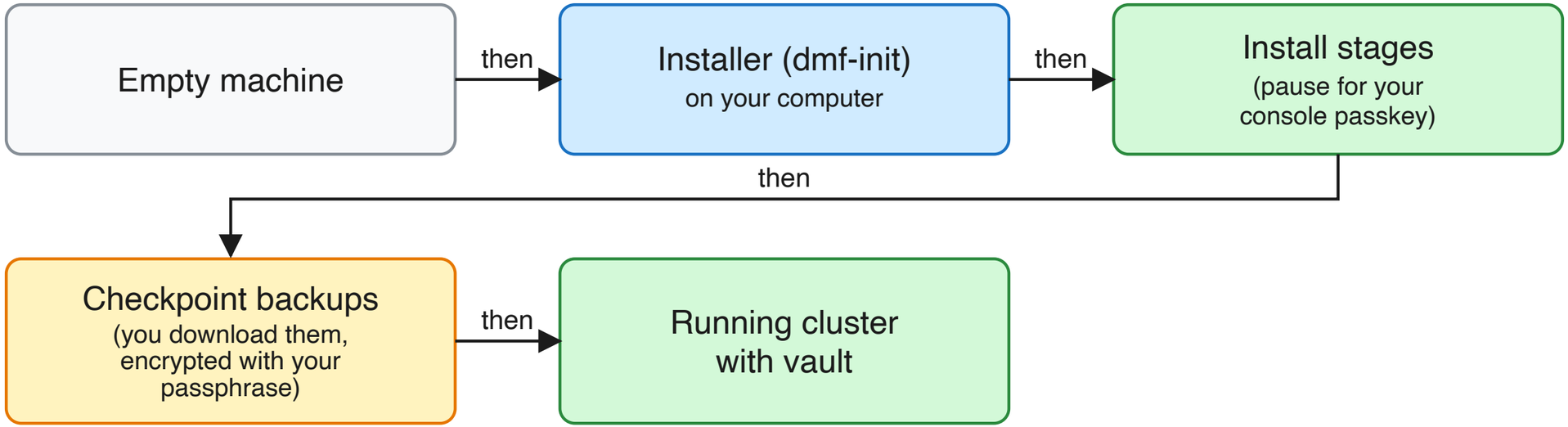
Full control means two things: a temporary root token for a planned change, and a restore from a backup.

The machine keeps an encrypted copy of the recovery keys and the seal key for each enrolled passkey. Your device decrypts it locally after a fingerprint, face or screen-lock check, only for the operation you approved.

The seal key opens the vault. The recovery keys approve root tokens and restores.

STEP 1 OF 9: INSTALL

Start with one empty machine



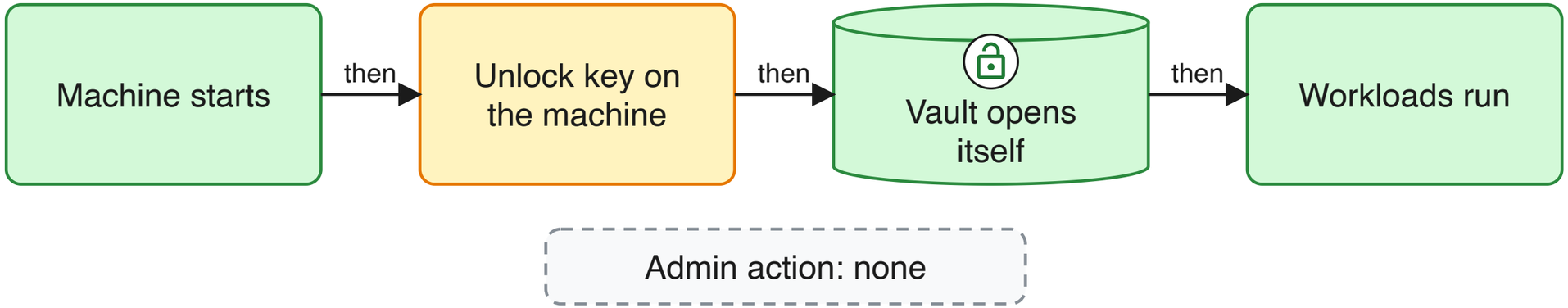
You do Start dmf-init on your own computer and point it at one empty machine.

You see The installer moves through its stages and asks for your console passkey. At each checkpoint it offers a backup to download, encrypted with your passphrase.

System holds The machine holds a running cluster, a local certificate authority, and one narrow policy for each change you can approve later. You hold the passphrase and the downloaded backups.

STEP 2 OF 9: FIRST UNLOCK

The machine unlocks itself



You do Nothing. The sandbox design has no manual unlock step at startup.

You see The cluster comes up with the vault open 🔓.

System holds The unlock key (the seal key) stays on the machine, by design. The recovery keys are not on the machine in plain form. Each enrolled passkey has an encrypted copy.

Enrol two passkeys

You do Register your first approval passkey, then enrol a second. A passkey lives on a phone, a laptop or tablet with a built-in authenticator, or a hardware security key with a PIN. The install is not complete without two.

You see The enrolment tells you that a takeover of your passkey sync account is a remote risk. The accepted risk of local access to the machine does not cover it.

System holds The system keeps an encrypted copy of the recovery keys and the seal key for each enrolled passkey, and records each enrolment. One passkey can approve alone.

A passkey synced to two devices is still one credential.

Keep the recovery package

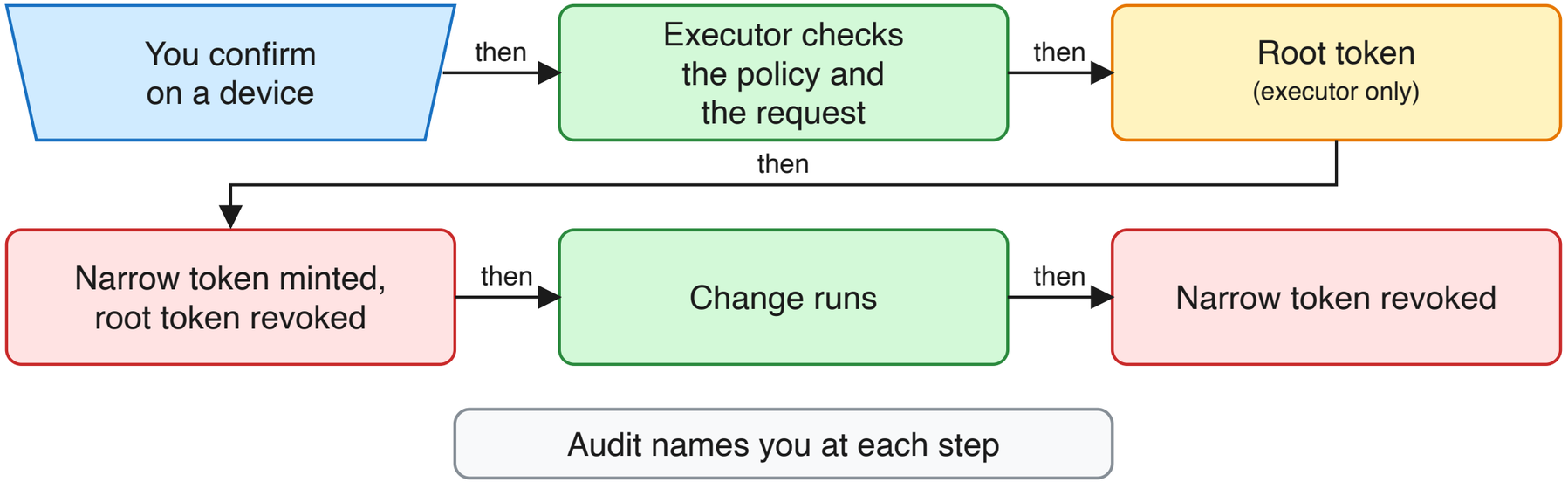
You do Keep the recovery package in your own custody. In the sandbox lane you are its only custodian.

You see How the package reaches you is a proposal for decision. It is separate from the installer's checkpoint backup.

System holds One direct copy of the unlock key (the seal key). The plan says the package approves when no passkey is available.

The material needed for replacement enrolment and check-in still needs to be specified.

A root token for one planned change

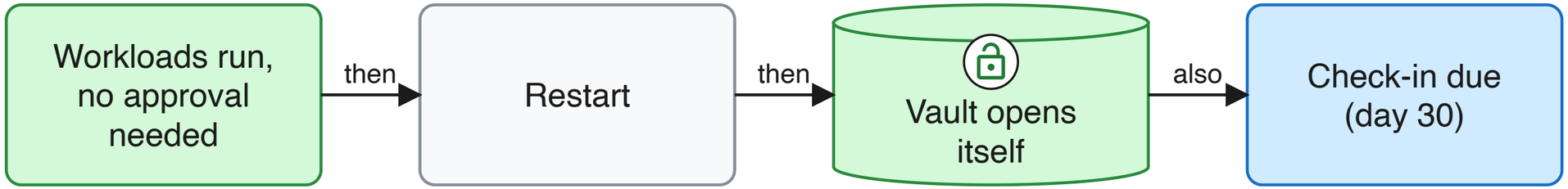


You do Start a privileged change. Sign in as the admin account first, then approve with your passkey. After the planned vault upgrade, a root token needs both.

You see The approval names the operation and shows a request fingerprint.

System holds The intended executor mints a narrow token, revokes the root token, runs the change, then revokes the narrow token. No token is kept. The audit names you at each step.

Most days, you do nothing

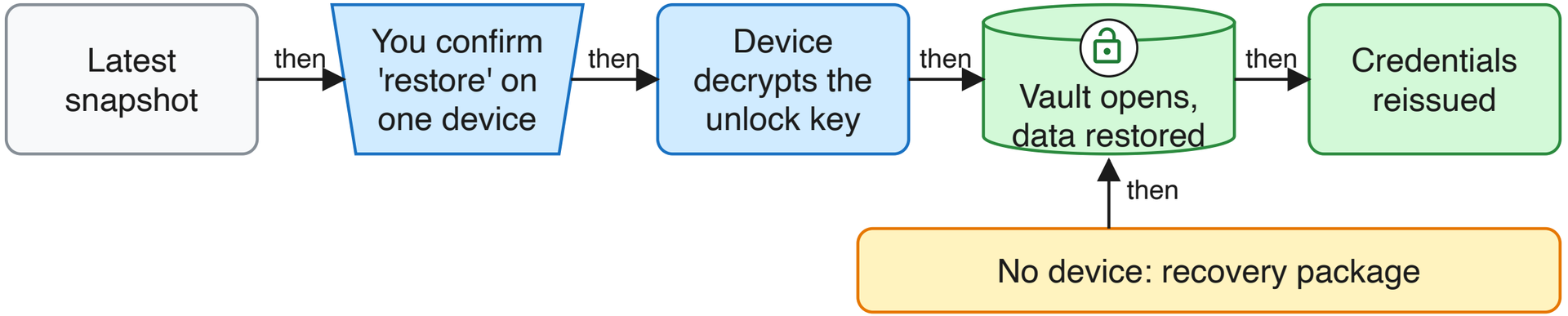


You do Approve rare privileged changes and check in when prompted.

You see Workloads keep running. If the machine restarts, the vault opens by itself.

System holds The machine stores the unlock key, the encrypted copies, audit records and the check-in deadline.

Restore from a snapshot with one confirmation



You do Start a restore in the installer and approve it with an enrolled passkey.

You see The approval screen names the operation "restore". You confirm once, with one passkey. If your authenticator is on another device, a QR code carries the confirmation to it.

System holds A copy of the unlock key is stored with the snapshot, encrypted for each passkey. The vault opens with the restored key. Your passkeys still approve, with no new enrolment.

Check in every 30 days

Why The check-in helps reveal a missing credential before the next privileged operation.

You do Confirm with an enrolled passkey. An approval also starts a new 30 days.

You see Warnings at 14, 7, 3 and 1 days, each with a one-tap check-in link, and the last check-in for each passkey.

If you miss it Workloads continue and the machine still unlocks itself. Privileged changes wait until a check-in or recovery path succeeds.

STEP 9 OF 9: LOSE A DEVICE

Lose a device, keep control

You do Remove the lost passkey. Your other passkey keeps approving on its own. Enrol a replacement in the console.

You see The system records the removal. The record states that snapshots taken before it still open with the old unlock key.

System holds Removal replaces the recovery keys and the seal key, and re-encrypts the copies for the remaining passkeys. The removed passkey's copy stops working. The recovery package is reissued.

SUMMARY

What each place holds

After step	The machine	Each enrolled passkey	Snapshots	Recovery package
1 Install	Cluster, unlock key, narrow policies	-	-	-
2 First unlock	Vault opens itself	-	-	-
3 Enrol	Encrypted copy per passkey, audit record	The passkey itself	Unlock key copy per passkey	-
4 Package	-	-	-	One direct copy of the unlock key
5 Root token	Audit records, no token kept	Same passkey, never sees the token	-	-
6 Normal day	Check-in deadline	Same passkey	-	-
7 Restore	Restored data	Passkey approves, no new enrolment	Latest snapshot used	Completes a restore if no passkey is available
8 Check-in	New deadline, last check-in per passkey	-	-	Can check in if no passkey is available
9 Lose a device	New recovery keys and unlock key, new copies	Removed passkey's copy stops working	Copies re-encrypted	Reissued

SUMMARY

What the sandbox design can promise

The machine opens the vault so the platform can run. Only you, with your passkey, can take full control.

Full control means a temporary root token for a planned change, and a restore from a backup.

The machine keeps an encrypted copy of the recovery keys and the seal key for each enrolled passkey. Your device decrypts it only for the operation you approved.

Someone who has only the machine's disk can read the vault data. That person cannot create a root token.

Design question: what a compromised running machine can capture during a later approval.

Installation and recovery package

Proposal for decision

Create the seal key and recovery keys during first install, before passkey enrolment.

Guide the admin through two independent credentials, a package download and verification.

Encrypt the package with its own passphrase. Keep the package and its passphrase away from the machine.

Specify and test the package material needed for restore, replacement enrolment and check-in.

Privileged changes and restore

Proposal for decision

Let the signed-in admin start a named privileged change in the console.

Show approval, running, success or failure, with an audit reference.

In dmf-init, show the restore point with its timestamp before confirming. The plan restores the latest snapshot, so choosing an earlier one needs a decision.

Start with hourly snapshots and a daily off-machine copy. Alert on stale backups and test restores.

Reminders and lost credentials

Proposal for decision

Use console warnings as the baseline. Offer optional email to a configured admin address.

A retained credential or the recovery package approves removal of a lost credential.

Allow removal when it leaves one credential. Warn and prompt the admin to add a backup. The plan says the lane needs at least two enrolled devices, so this needs an exception.

Count independent credentials. Two devices sharing one synced passkey do not provide independent credentials.

Separate console sign-in from approval

Proposal for decision

Enrol separate credentials for console sign-in and approval of privileged actions.

Explain their different roles in one guided setup.

An extra enrolment and potentially an extra prompt buy independent lifecycle and revocation.

Review the approval client and executor trust boundary before promising protection from machine administrators.